

Error Handling & Logging Strategy

MDMIS Backend Design | Phase 1-2 | June 2026 | Confidential

1. Overview

This document defines how MDMIS surfaces errors to API consumers, prevents sensitive information leakage, and captures structured logs and traces for debugging and compliance. Every failure is visible, categorised, and actionable. There are no silent errors.

2. Standard API Error Response Format

All error responses use a single consistent JSON envelope. Clients must never parse HTTP status codes alone — the **code** field provides machine-readable classification.

```
{ "error": { "code": "SCAN_NOT_FOUND", // machine-readable, snake_upper "message": "Scan session not found.", // human-readable, safe for UI display "details": { "scan_id": "abc-123" }, // optional structured context "request_id": "req-7f3a...", // correlates to server logs "timestamp": "2026-06-25T10:42:00Z" } }
```

NEVER include stack traces, internal file paths, database error messages, or environment details in any error response sent to clients.

3. HTTP Status Code Mapping

HTTP Status	Error Code	When Used
400 Bad Request	VALIDATION_ERROR	Request body or query param failed schema validation
401 Unauthorized	TOKEN_EXPIRED / INVALID_TOKEN	JWT missing, expired, or invalid signature
403 Forbidden	INSUFFICIENT_ROLE	Authenticated but role lacks required permission
403 Forbidden	TENANT_MISMATCH	Resource belongs to a different organisation
404 Not Found	RESOURCE_NOT_FOUND	Requested entity does not exist in caller's org scope
409 Conflict	DUPLICATE_RESOURCE	Unique constraint violation (e.g. duplicate COC ID)
413 Payload Too Large	FILE_TOO_LARGE	Upload exceeds 10 GB limit (REQ-ING-003)
422 Unprocessable Entity	INVALID_FILE_FORMAT	File parsed but failed geospatial or sensor validation
429 Too Many Requests	RATE_LIMIT_EXCEEDED	Auth endpoint rate limit hit — includes Retry-After header
500 Internal Server Error	INTERNAL_ERROR	Unhandled exception; Sentry alert fired; request_id logged
503 Service Unavailable	ML_SERVICE_UNAVAILABLE	ML classifier down; graceful degradation active (REQ-REL-003)

4. Exception Handling Architecture (FastAPI)

A global exception handler is registered at application startup. It catches all unhandled exceptions, logs them with a unique request_id, fires a Sentry alert, and returns the standard 500 envelope. Domain-specific exceptions inherit from **MDMISException** and are caught by a dedicated handler that maps them to the correct HTTP status.

Exception hierarchy:

MDMISException (base) --- AuthException (401 / 403) --- TenantException (403 TENANT_MISMATCH) ---
NotFoundException (404) --- ValidationException(400 / 422) --- ConflictException (409) ---
ServiceException (503 – external service down)

All Celery background tasks catch exceptions, log them with the job_id and user context, retry up to 3 times with exponential backoff, then mark the job as FAILED and notify via Sentry. The user receives a status update — never a silent hang.

5. Input Validation & Sanitisation

Target	Rule
API payloads	Pydantic v2 models on every request. Type errors -> 400 VALIDATION_ERROR with field-level detail
File uploads	Format check, bounding box presence, sensor type ID, min size — before storage or processing (REQ-ING-001)
SQL injection	SQLAlchemy ORM parameterised queries only. Raw SQL prohibited (REQ-SEC-004)
XSS	All text fields HTML-escaped before storage; Content-Security-Policy header on all responses
CSRF	SameSite=Strict on cookies; CSRF token required on state-changing web portal forms
File content	ClamAV malware scan completes before any file is made available for processing (REQ-ING-008)
GPS coordinates	Bounding box validated: lat in [-90,90], lon in [-180,180]; WGS84 projection enforced

6. Logging Strategy

All logs are structured JSON emitted to stdout (collected by the container orchestrator). Library: **structlog**. Every log line includes a **request_id** for distributed tracing.

Log Levels

Level	When to Use
DEBUG	Dev / staging only. Detailed internal state — never enabled in production.
INFO	Normal operations: request received, job started/completed, user login, ingestion complete.
WARNING	Recoverable issues: external API retry, confidence below threshold, deprecated model version used.
ERROR	Handled failures: file validation failed, auth locked out, external service timeout.
CRITICAL	Unhandled exceptions caught by global handler. Triggers immediate Sentry alert.

Mandatory fields on every log line:

```
{ "timestamp": "2026-06-25T10:42:00.123Z", // UTC ISO 8601 "level": "INFO", "request_id":  
"req-7f3a9b...", // UUID per HTTP request "user_id": "usr-abc...", // null for unauthenticated "org_id":  
"org-xyz...", // null for unauthenticated "service": "api | worker | scheduler", "event":  
"scan_upload_complete", // snake_case event name "data": { ... } // context – no PII, no secrets }
```

NEVER log: passwords, tokens, API keys, raw sensor file content, personally identifiable information (PII), or full stack traces visible to end users.

7. Immutable Audit Trail

A separate **audit_log** table records every sensitive action. Rows are append-only (no UPDATE or DELETE permitted). Retained for 7 years (REQ-RPT-005, REQ-DO-002). MDMIS System Admin access to client org data is always logged here (REQ-SEC-006).

Field	Type	Purpose
user_id	UUID	Who performed the action
org_id	UUID	Which organisation context
action	ENUM/TEXT	e.g. LOGIN, SCAN_UPLOAD, REPORT_GENERATED, ROLE_CHANGED, MODEL_DEPLOYED
resource_id	UUID	ID of the affected record
ip_address	INET	Client IP address
timestamp	TIMESTAMP	UTC — set by server, immutable
before_value	JSONB	Snapshot before change (for edits)
after_value	JSONB	Snapshot after change (for edits)

8. Error Monitoring & Alerting

Component	Behaviour
Sentry	Exception tracking for API + workers. Captures: stack trace, request context, user/org ID. Alerts dev team on first occurrence of any new error (Go-Live #17)
Health endpoints	GET /health/live (container alive) and GET /health/ready (DB + Redis + ML reachable). Used by load balancer and Kubernetes probes.
Graceful degradation	If ML classifier is unreachable: ingestion, map viewing, and report access remain functional. UI shows a banner indicating reduced capability (REQ-REL-003).
Background job failures	Celery tasks retry 3x with exponential backoff. Permanent failure sets job status to FAILED and sends an in-app + email notification to the triggering user.
External API failure	If SendGrid / Africa's Talking / commodity price API is down: request is queued in Redis for retry. Sentry warning fired after 3 consecutive failures.